

Eng 3.9. Auditing and Monitoring

Task 1 - Introduction

Auditing is like a check-up for a company or organisation. It involves carefully examining the company's processes, internal controls, and financial statements to ensure everything runs smoothly according to the policies and laws. Auditors look for problems, such as errors, inefficiencies, or shady activities, and suggest ways to fix them. This helps the company improve its operations and builds trust with the people involved or affected by the organisation's activities.

In more formal terms, auditing is a systematic, independent, and objective process of gathering and evaluating evidence to determine if an organisation, its policies, processes, controls, or financial statements comply with applicable laws, regulations, and industry standards.

In information systems, monitoring is about continually checking a computer's or network's performance and behaviour. It involves watching over various components such as applications, storage, and networking to make sure they're working well together. Monitoring also looks for unusual behaviour and checks if anything violates established rules or policies.

Answer the questions below

What do you call the systematic review of an organisation's technological infrastructure, policies and operations?

Auditing

What do you call the continuous observation of an organisation's computer technologies and related resources?

Monitoring

Task 2 - Audit Objectives and Types

The audit of information systems has more encompassing objectives. The objectives of an information systems audit are to evaluate the **effectiveness, security, and compliance** of systems and data management within an organisation. By conducting an information systems audit, auditors can assess various aspects of an organisation's IT

infrastructure, processes, and controls. Some primary objectives of an information systems audit include the following:

- **Assess the effectiveness of internal controls:** This process can help mitigate the risk of fraud, errors, and other disruptions to the organisation's operations.
- **Identify and assess risks:** This process can help the organisation develop and implement appropriate controls to mitigate risks to the organisation's information systems.
- **Assess the efficiency and effectiveness of information systems:** This process can help the organisation improve the performance of its information systems and make better decisions about future investments in information technology.
- **Ensure compliance with laws and regulations:** This process can help protect the organisation from fines, penalties, and other legal sanctions.

In more formal terms, information systems audit serves the following objectives:

- **Risk assessment:** Identify potential risks and vulnerabilities that may affect information assets' confidentiality, , and availability and evaluate risk mitigation strategies in place.
integrity
- **Regulatory compliance:** Ensure that an organisation's information systems adhere to relevant laws, regulations, and industry standards to avoid legal violations and safeguard the organisation's reputation.
- **IT governance:** Evaluate the effectiveness of IT governance practices, including decision-making processes, resource allocation, and performance management within the organisation.
- **Security management:** Assess the effectiveness of an organisation's information security policy, processes, and controls in protecting information assets from unauthorised access, use, modification, and disclosure.
- **Operational and performance evaluation:** Assess the controls and processes for key IT activities such as system design, development, implementation, and ongoing maintenance, ensuring that the organisation's systems and resources are utilised efficiently and that desired goals and outcomes are achieved.
- **Data management and quality:** Evaluate the processes and controls for data storage, retention, backup, and recovery to ensure that critical data is accurate, complete, reliable, and available when needed.

- **Business continuity and disaster recovery:** Assess the adequacy of an organisation's strategies for maintaining critical IT services and capabilities during various business disruptions, including assessing backup and contingency plans to ensure timely recovery.
- **Fraud detection and prevention:** Identify fraudulent activities or misuse of resources by examining user activity, authorisation, and the overall control environment.

By identifying potential vulnerabilities, weaknesses, or irregularities, IT auditors help prevent unauthorised access, data breaches, system failures, and legal violations, strengthening information security and ensuring the integrity, confidentiality, and availability of critical IT resources and information assets.

Audit Types: One way to classify audits is based on who is performing the audit:

- **Internal audits:** These are performed by an organisation's personnel or staff members assigned to the internal audit function.
- **External audits:** External audits are conducted by independent auditors not employed by the organisation being audited. These auditors are typically from external accounting or auditing firms, and the primary purpose is to provide an impartial and objective review.

Answer the questions below

| Which type of audit is conducted by independent auditors?

External Audit

| Which type of audit is conducted by an organisation's own personnel?

Internal Audit

Task 3 - Audit Frameworks

An audit framework is a structured approach comprising principles, concepts, and practices used to conduct an audit. It provides guidelines on planning, executing, and reporting on an audit effectively and ensures that audits are objective and consistent. Audit frameworks help auditors assess an organisation's policies, processes, controls, and compliance with regulations while providing efficiency, value, and transparency to the audit process.

Popular Audit Frameworks

Framework	Description	Industries	Notes
COSO	Internal control framework that helps organisations design, implement, and monitor their internal controls.	All industries	COSO is a comprehensive framework that covers all aspects of internal control.
COBIT	IT governance framework that helps organisations align their IT with their business goals.	All industries	COBIT is a flexible framework that can be adapted to the needs of any organisation.
ISAE 3402	Assurance standard that provides assurance on the controls of a service organisation.	All industries	ISAE 3402 is a relatively new standard gaining popularity in the financial services industry.
ISO 27001	Information security management system (ISMS) standard that helps organisations protect their information assets.	All industries	ISO 27001 is the world's most widely adopted ISMS standard.
ITIL	IT service management (ITSM) framework that helps organisations deliver high-quality IT services.	All industries	ITIL is a well-established framework that organisations of all sizes use.
PCI DSS	Payment Card Industry Data Security Standard that helps organisations protect cardholder data.	Financial services	PCI DSS is a mandatory standard for organisations that process credit and debit card payments.
SOX	Sarbanes-Oxley Act that sets requirements for internal controls over financial reporting.	Publicly traded companies	SOX is a complex law that has a significant impact on public companies.

Answer the questions below

What is the standard used by organisations that process card payments?

PCI DSS

Who developed ITIL?

CCTA

Who developed COBIT?

ISACA

Task 4 - Auditing IT Infrastructure and Operations

Audit Process

- **Planning:** The auditor determines the audit's scope, objectives, and timelines. This stage involves understanding the organisation's IT environment – including infrastructure, systems, applications, security measures, and data management practices – and identifying potential risks and controls to be evaluated.
- **Information gathering:** The auditor collects relevant data, background information, and documentation to thoroughly understand the organisation's IT processes and systems. This process typically involves interviewing key personnel, reviewing resource documentation, analysing procedures and policies, and examining the control environment.
- **Risk assessment and control evaluation:** The auditor identifies and assesses the risks and vulnerabilities within the organisation's IT infrastructure, processes, and systems based on the information gathered. This process includes evaluating the effectiveness of internal controls, security measures, and compliance with applicable policies, regulations, and industry standards.
- **Testing:** The auditor performs detailed tests on selected systems, applications, specific processes or control procedures to validate their effectiveness, accuracy, and compliance. Testing methods may include data analysis, vulnerability scanning, penetration testing, controls testing, or sampling, depending on the audit objectives and the audited systems.
- **Analysis and findings:** The auditor analyses the testing and evaluation results, identifies deviations, irregularities, or vulnerabilities, and evaluates the implications. Auditors determine if systems are configured securely, IT processes are effective and compliant, or risks are adequately mitigated.
- **Reporting:** After the analysis, the auditor documents the findings and conclusions, makes recommendations for improvement where necessary, and prepares a formal audit report. This report is then shared with the management, the audit committee, or other stakeholders as required, helping them understand the organisation's risk exposure, compliance, and effectiveness of IT processes and controls.

- **Follow-up:** In some cases, a follow-up may be performed to evaluate if the recommended improvements and corrective actions have been implemented and ensure their effectiveness in addressing the identified issues.

Audit Areas: The following is a list of some areas that we might consider inspecting when performing an information systems audit:

- **Information Systems Hardware:** Inspect the hardware configuration and performance to ensure it meets the organisation's needs.
- **OS:** Check the operating system configuration and security to ensure it is secure and compliant with organisational policies.
- **File Systems:** Check the file system permissions and access control to ensure that sensitive data is protected.
- **Database Management Systems:** Audit the database configuration and security to ensure it is secure and compliant with organisational policies.
- **Network Infrastructure:** Inspect the network configuration and security to ensure it is secure and compliant with organisational policies.
- **Network Operating Controls:** Audit the network operating controls to ensure that they effectively prevent unauthorised access to the network.
- **IT Operations:** Examine the IT operations to ensure they effectively deliver high-quality IT services.
- **Lights-Out Operations:** Check the lights-out operations to ensure they effectively manage IT infrastructure without the need for human intervention.
- **Problem Management Operations:** Audit the problem management operations to ensure that they effectively resolve IT problems in a timely manner.
- **Monitoring Operations:** Validate the monitoring operations to ensure they effectively detect and respond to IT incidents.
- **Procurement:** Check the procurement process to ensure that IT hardware and software are secure and compliant.
- **Business Continuity Planning:** Inspect the business continuity plan to ensure that it effectively ensures the continuity of critical IT services during a disaster.
- **Disaster Recovery Planning:** Examine the disaster recovery plan to ensure it effectively recovers critical IT services during a disaster.

Audit Scenario

Step 1: Planning: The details of the COBIT controls are beyond the scope of this room. However, for this exercise, we need to know that the COBIT controls provide a framework for ensuring that IT activities are aligned with the organisation's strategic goals and objectives.

Step 2: Execution:

- **Gather evidence:** We start this stage by gathering evidence of the organisation's compliance with the relevant COBIT controls. This evidence may include documentation, interviews, and observations.
- **Assess the evidence:** Next, we assess the evidence to determine whether the organisation complies with the relevant COBIT controls.

Step 3: Assessment

- **Identify gaps in compliance:** First, we must identify gaps in the organisation's compliance with the relevant COBIT controls.
- **Make recommendations for improvement:** Next, we can make recommendations for improvement to the organisation's IT governance practices.

Step 4: Reporting

- **Prepare the audit report:** We begin by preparing an audit report summarising the audit findings and making recommendations for improvement.
- **Communicate the audit report:** Once the report is ready, we must communicate it to the organisation's management and stakeholders.

Step 5: Follow-up

- **Monitor the implementation of recommendations:** Ideally speaking, we will be able to monitor the implementation of the recommendations made in the audit report to ensure that the organisation is taking steps to improve its IT governance practices.

In the following questions, consider the case where we divide the audit process into the following five stages:

1. Planning
2. Execution
3. Assessment
4. Reporting
5. Follow-up

Answer the following questions with the number of the related step.

Answer the questions below

Which step do we present our findings about non-conformities, weaknesses and issues noted?

4

At which stage does an organisation review the steps based on recommendations for proper and satisfactory implementation?

5

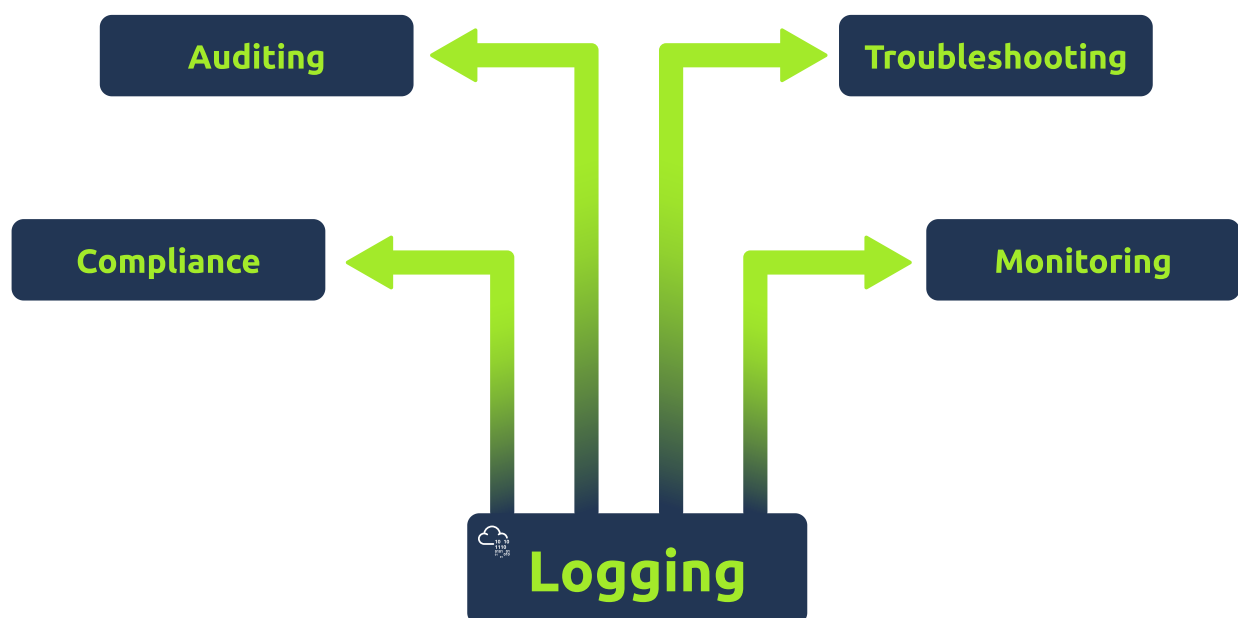
At which stage do the auditors establish the audit scope and define its objectives?

1

Task 5 - Logs

Logging is the process of recording events as they take place on a computer system. These events can be:

- Problems and errors
- Information about current operations



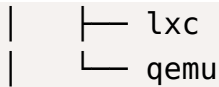
Some of the purposes of logging are:

- **Troubleshooting:** Logs can be a valuable tool for troubleshooting errors. For instance, if a server fails to start, we would look at its logs to discover where it failed and what prevented it from starting.
- **Monitoring:** Logs provide plenty of insight into the utilisation of a system's resources. Consider the case where a server is slow, and we want to discover the bottleneck affecting its performance. The system might run low on memory, or the CPU might reach 100% utilisation for non-trivial durations. Logs can provide the necessary insights to pinpoint and solve the problem.
- **Auditing:** Logs record users' activities on a given system. On an audited system, we want to know who logged in, what files they accessed, and what changes they made. This information is necessary to audit a system or investigate any incident.
- **Compliance:** Logs can be a requirement to maintain compliance with relevant regulations. For instance, financial institutions need to keep logs of all financial transactions that take place.

Task 6 - Log Management on Linux

Most Linux distributions store the log files and directories in `/var/log`. An example `/var/log` directory content is shown in the terminal below.

```
root@TryHackMe# sudo tree /var/log -d -L 2
/var/log
├─ akmods
├─ anaconda
├─ audit
├─ blivet-gui
├─ chrony
├─ cups
├─ displaylink
├─ gdm
├─ glusterfs
├─ httpd
├─ journal
├─ f29b4ed41359484da9b7d3bf3ec279ac
├─ libvirt
└─ libxl
```



For handling logs, many Linux distributions use system logging daemons like `rsyslog`, `syslog-ng`, and `journald` to manage, process, and store log events.

Log Types: There are several different types of logs on a Linux system. Some common types of logs include:

- **System logs:** These logs contain information about the general health and operation of the system.
- **Application logs:** These logs contain information about the specific applications running on the system.
- **Security logs:** These logs contain information about security-related events, such as login and failed authentication attempts.

Managing Logs on a Linux System: To efficiently work with Linux logs, we need to consider the following:

- Log to a central location
- Use a tool to filter and parse the logs
- Setup alerts

Practical Example: Click on the **Start Lab Machine** button to follow along.

- Username: `maxine`
- Password: `AuditMe!`

Because all the commands require root or sudo privileges, you can issue `sudo su` to get root access and avoid typing `sudo` before each command. One of the efficient command-line tools to audit system logs on a Linux system is `aureport`. You can get a summary of the events using the command `aureport --summary`. If you are only interested in the failed events, you can use `aureport --failed` as shown in the terminal window below.

```
root@TryHackMe# aureport --failed
```

```
Failed Summary Report
```

```
=====
```

```
Range of time in logs: 06/08/2023 12:18:12.635 - 07/06/2023 23:09:
```

```
20.083
Selected time for report: 06/08/2023 12:18:12 - 07/06/2023 23:09:2
0.083
Number of changes in configuration: 0
Number of changes to accounts, groups, or roles: 5
Number of logins: 0
Number of failed logins: 87
Number of authentications: 0
Number of failed authentications: 421
[...]
```

We can quickly spot the high number of failed logins and authentications: **87** and **421**. Please note that the number of failed authentications is higher than the number of failed logins, as one failed login results in multiple failed authentications, depending on the system setup. Let's discover which account has a high number of failed logins.

The following command `ausearch --message USER_LOGIN --success yes --interpret` returns successful logins, while `ausearch --message USER_LOGIN --success no --interpret` returns the failed logins. The options are:

- `-message` is followed by the message we are interested in searching for. Examples include `USER_LOGIN`, `DEL_USER`, `ADD_GROUP`, `USER_CHAUTHOK`, `DEL_GROUP`, `CHGRP_ID`, `ROLE_ASSIGN`, and `ROLE_REMOVE`.
- `-success` is followed by `yes` or `no` depending on whether you are searching for successful or unsuccessful attempts, respectively.
- `-interpret` converts numeric entities, such as UID (User ID), into text.

If we only want to display the failed login attempts for the `root` account, we can pipe the output via `grep`. The command becomes `ausearch --message USER_LOGIN --success no --interpret | grep ct=root`.

The command above would result in a very long list. Since we are interested in counting the lines, we can pipe the output again through `wc -l`. `wc` is used for counting characters, words, and lines. The `-l` will only display the line count. Consequently, a straightforward way to count the number of failed `root` logins is by issuing the following command.

```
root@TryHackMe# ausearch --message USER_LOGIN --success no --interpret | grep ct=root | wc -l
```

76

The command above can be written in its short form as shown below:

```
root@TryHackMe# ausearch -m USER_LOGIN -sv no -i | grep ct=root | wc -l
```

76

The output above tells us that 76 failed login attempts have been at the root account.

Answer the questions below

Using aureport, how many failed logins have occurred so far?

263

```
root@ip-10-113-97-217:~# ssh maxine@10.113.140.193
The authenticity of host '10.113.140.193 (10.113.140.193)' can't be established.
ED25519 key fingerprint is SHA256:ypN+rbLUow5SxZNJui1TDlZ5Nue3LrJrtR15fy4D0YY.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.113.140.193' (ED25519) to the list of known hosts.
maxine@10.113.140.193's password:
Activate the web console with: systemctl enable --now cockpit.socket

Last login: Mon Jun 22 07:41:14 2026 from 10.113.96.209
[maxine@ip-10-113-140-193 ~]$ sudo aureport --failed
[sudo] password for maxine:

Failed Summary Report
=====
Range of time in logs: 06/08/2023 12:18:12.635 - 06/22/2026 07:44:50.427
Selected time for report: 06/08/2023 12:18:12 - 06/22/2026 07:44:50.427
Number of changes in configuration: 0
Number of changes to accounts, groups, or roles: 6
Number of logins: 0
Number of failed logins: 263
Number of authentications: 0
Number of failed authentications: 1536
Number of users: 4
Number of terminals: 8
Number of host names: 6
Number of executables: 19
Number of commands: 17
Number of files: 119
Number of AVC's: 20
Number of MAC events: 0
Number of failed syscalls: 299
```

Using ausearch, how many failed logins are related to the username mike?

4

```
[maxine@ip-10-113-140-193 ~]$ sudo ausearch --message USER_LOGIN --success no --  
interpret | grep acct='root' | wc -l  
227  
[maxine@ip-10-113-140-193 ~]$ sudo ausearch --message USER_LOGIN --success no --  
interpret | grep acct='mike' | wc -l  
4
```

Using ausearch, how many failed logins are related to the username root?

227

```
[maxine@ip-10-113-140-193 ~]$ sudo ausearch --message USER_LOGIN --success no --  
interpret | grep acct='root' | wc -l  
227  
[maxine@ip-10-113-140-193 ~]$
```

Task 7 - Log Management on MS Windows

Windows logs, sometimes referred to as event logs, form an integral part of the operating system's functionalities, providing insights into system behaviour and potential issues. Four primary types include:

- **System Logs:** This records activity associated with the system components, such as driver failure, resource conflict, and hardware issues. For IT professionals, they serve as sources of critical diagnostics information.
- **Application Logs:** This type concerns individual software living upon the system. When issues manifest around a specific application, such as failing to connect to a database or process-related bottlenecks, these logs come in handy to determine why the failure occurred.
- **Security Logs:** Specialised logs designed to track security events. They touch on events such as logon and logoff actions, user rights assignments, policy changes, and security-related aberrations. For security professionals, this often represents their first check when investigating a security incident.
- **Forwarded Events Logs:** These logs receive collected from other tertiary-tertiary computing environments. They act as collated reports, pulling from multiple sources into a centralised file. They are ideal for monitoring tasks and analysis in a networked environment, where you may need to assemble data from various places into a cohesive analysis.

Correctly analysing Windows logs empowers administrators to address security issues promptly, facilitating strong performance and troubleshooting any potential problems efficiently. The table below provides a short and basic comparison between Linux logs and Windows logs.

Feature	Linux Logs	Windows Logs
Location	<code>/var/log</code>	<code>%SystemRoot%\System32\Logfiles</code>
Format	Syslog	EventLog
Logging levels	Debug, Info, Notice, Warning, Error, Critical	Debug, Information, Warning, Error, Critical
Tools for viewing logs	<code>tail</code> , <code>grep</code> , <code>less</code>	Event Viewer
Advantages	More flexible, easier to parse	More user-friendly, more integrated with Windows
Disadvantages	Can be less intuitive, less centralized	Can be more difficult to troubleshoot

Audit Policy: Microsoft Windows makes it possible to audit various aspects of the system. Here is a list of example events you can audit:

- Account logon events
- Account management
- Privilege use
- Directory service access
- Policy change
- System events

Windows Event Viewer: Let's start the Event Viewer, then open Security under the Windows Logs. We can see the different events that have occurred, including those we configured MS Windows 2019 to log as part of auditing. In the screenshot below, we have selected an event with ID 4624, i.e., a user has successfully logged in to a system.



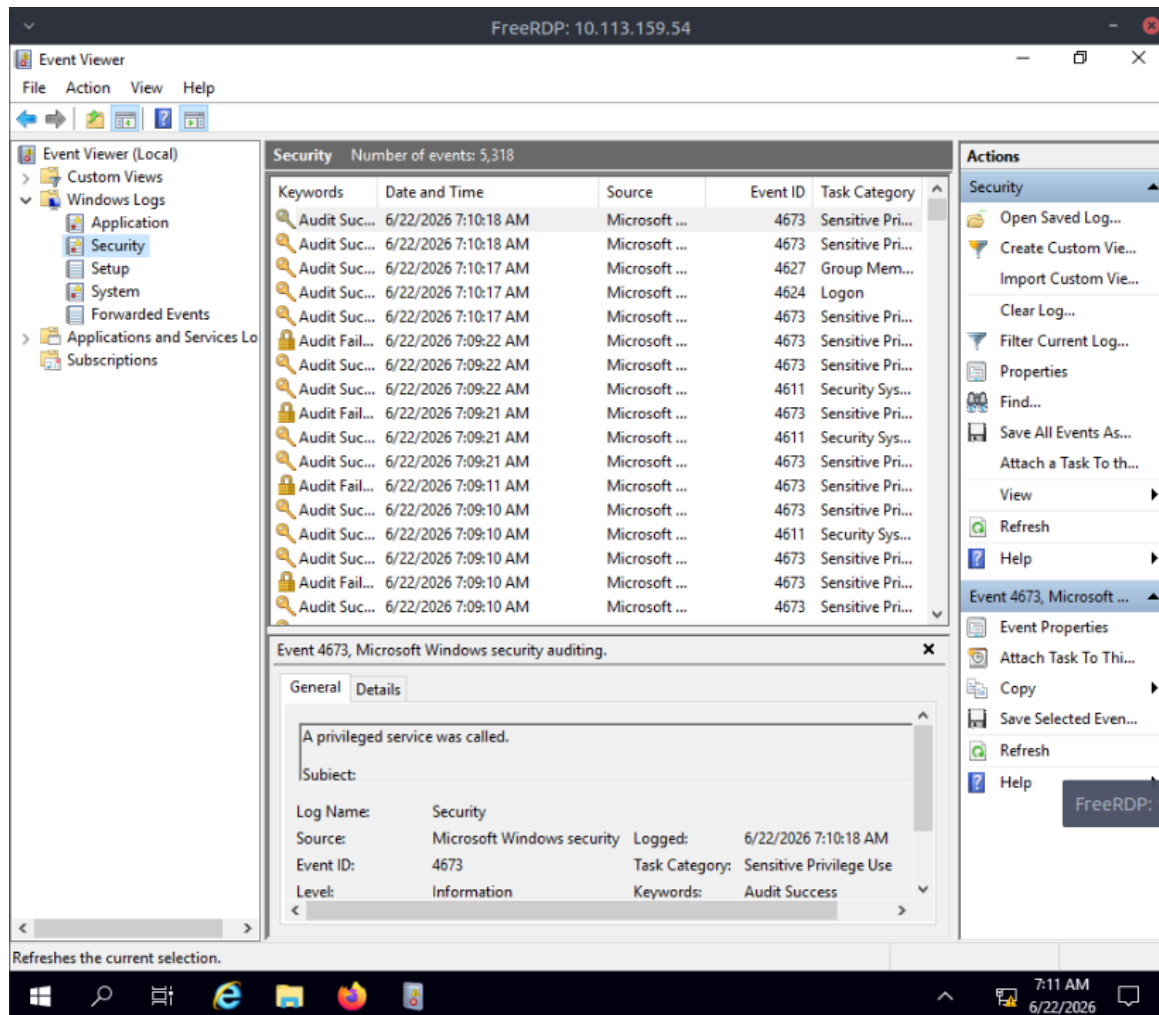
Logon events	Description
4624	A user successfully logged on to a computer.
4625	Logon failed due to an unknown username or a wrong password.
4634	The logoff process was completed.
4647	A user started the logoff process.
4779	A user disconnected from a remote session without logging off.

What happens when it runs?

xfreerdp initiates an RDP connection to 10.113.159.54.

It attempts to log in using: Username: dawn , Password: AuditMe!

If authentication succeeds and RDP is enabled on the target system, a remote desktop session opens, allowing the user to interact with the remote machine graphically.



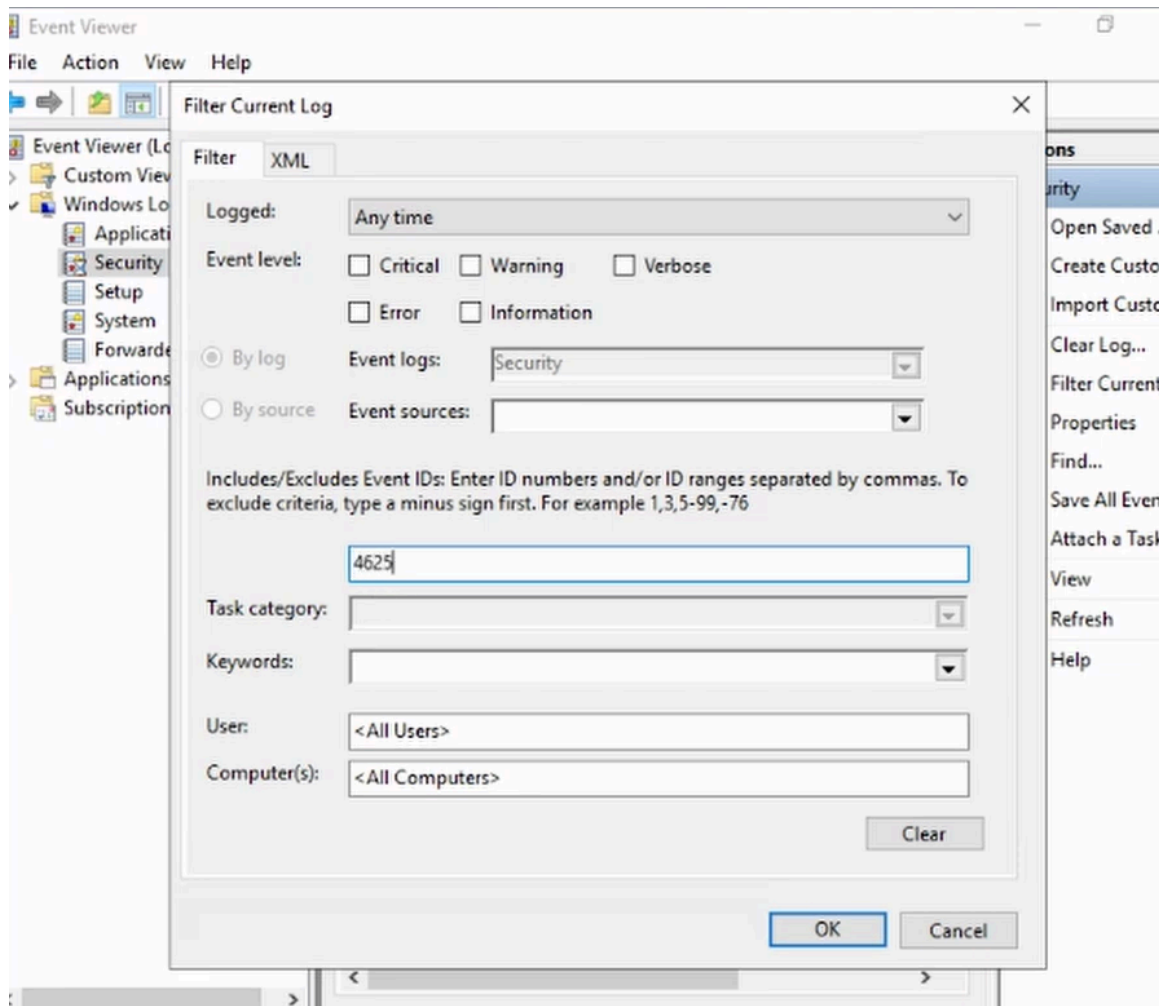
Answer the questions below

What is the event ID for a failed login attempt?

4625

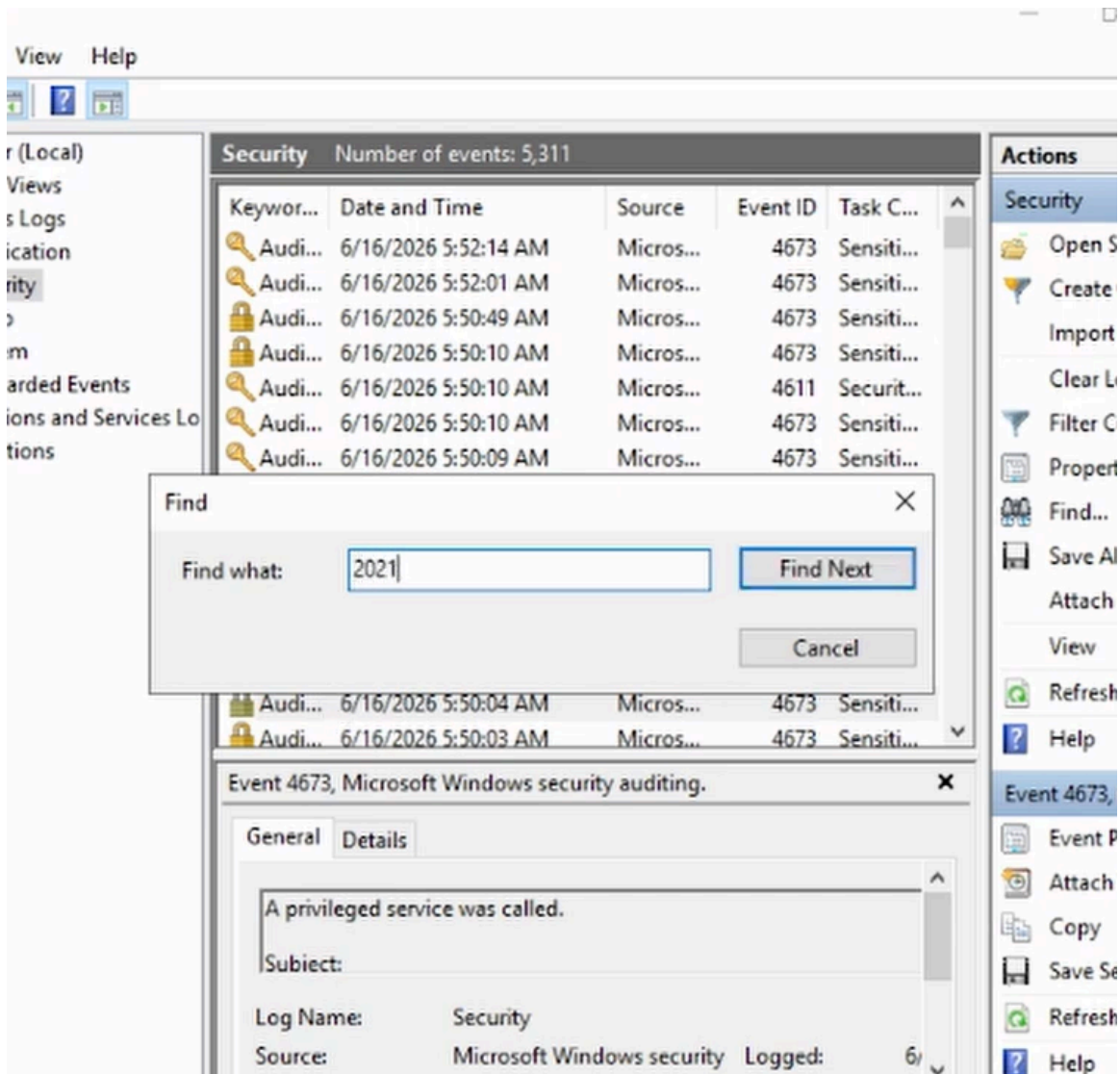
How many failed login attempts do you have under the security events?

2



How many failed login attempts took place in 2021?

1



Task 8 - Monitoring

Monitoring is crucial for several reasons:

- **Troubleshooting and Maintenance:** Monitoring data helps IT support teams identify and rectify operational faults more efficiently, ensuring systems run smoothly and effectively with minimum downtime.
- **Performance Optimisation:** By keeping track of information usage, transmission rates, and latency, fine-tuning strategies can be applied to optimise the performance of the systems.
- **Preventing Failures:** Proactively spotting potential issues or irregular patterns, such as close-to-capacity servers or faulty hardware, forms a significant aspect of

preventing more significant failures.

- **Security Risk Mitigation:** Continuous monitoring helps identify unauthorised access, security breaches, or malicious activity, enabling immediate reaction and thus enhancing system security.
- **Regulatory Compliance:** Continuous monitoring is crucial for organisations under regulatory controls to meet and prove compliance with data protection and privacy laws.

	Logging	Monitoring
Primary Function	To record system activities for later review	To deliver real-time observation of system status
Error Detection	After it hits, provides a data trail to backtrack the issue	Identify and notify irregularities as they occur
Process	A constant, passive process recording activities and system changes	An active, ongoing process receiving alerts or warnings based on predefined triggers
Typical Uses	Error diagnostics post-issue, compliance proof, audit trails, forensic analysis	Daily operational tracking, preventative maintenance, bottlenecks detection, real-time functionality and security
Timeliness of Notification and Inspection	Used primarily for retrospective analysis of problems	Real-time reporting of potential issues
Key Objectives	Error diagnosis, accountability and providing detailed context	Eradicate small issues from escalating and becoming larger problem

Task 9 - SIEM Basics

Security Information and Event Management (SIEM) is a set of integrated management technologies that provide a holistic view of an organisation's information security. SIEM systems collect and aggregate log data generated throughout the organisation's IT infrastructure from network devices, systems, and applications.

SIEM software then identifies and categorises incidents and events and analyses them. This analysis can be beneficial for identifying issues such as security threats, compromised systems, and malicious activities. It can also help with potential incident response actions.



The key capabilities of SIEM technology include:

- **Data Aggregation:** It can collect data from many sources, such as network devices, security controls, servers, and databases, providing a global perspective of the IT environment.
- **Correlation and analysis:** SIEM systems can correlate different events and logs to see patterns of possible malicious activity.
- **Alerting and reporting:** Based on the analysis performed on data, SIEM can automatically raise alerts upon identifying any abnormal activity and create

dashboards/reports for IT administrators.

- **Forensic Analysis:** It helps perform historical analysis against the event data for investigating and mitigating cyber threats.
- **Threat intelligence Feeds:** Many SIEM tools integrate threat intelligence feeds to enhance incident detection and proactively identify external threats.
- **Automation and Orchestration:** Some sophisticated SIEMs will also have capacities to automatically respond to some detected incidents, for example, by blocking IP addresses or deactivating vulnerable services.

Task 10 - Conclusion

Logging, monitoring, and auditing are critical components of data management and cyber security strategies. And logging, monitoring, and auditing foster a system environment with enhanced security, credibility, performance, and regulatory integrity.

Logging captures detailed event records about system operations, often serving as the first point of reference in troubleshooting or system optimisation.

Monitoring is a real-time continuation of the logging process, offering immediate glimpses into system health and performance and the capacity to identify potential problems before they escalate.

Auditing provides a systematic review of logs and monitoring histories necessary for regulatory compliance. It helps identify discrepancies or issues, attributing accountability for system actions.

	Logging	Monitoring	Auditing
Definition	Recording of system activities and changes	Real-time data and report collection to observe system status	Systematic analysis and review of actions within the systems
Main function	Stores a historical account of system processes, activities, or events	Records and visualises the live state of systems	Checks compliance with set IT standards and corrective actions
Result identification	Often post-issue or upon check	Real-time, at the time of anomaly or breach	Usually post-action, during compliance checks
Process flow	Operates passively to collect data as events transpire	Active process analysing and inspecting system performance regularly	Performed at set times, often periodic, can be triggered by events

	Logging	Monitoring	Auditing
Uses	Find faults, debug, forensics, assists in audits	Maintain system performance, real-time fault-tracking, foreseeing issues	Validate regularity, safety inspection, prove accountability and lessening potential risks
Key Role	Data gathering and accountability	Preventive and predictive maintenance	Compliance, verification, and legal professionalism